SIZMA TESTİ RAPORU

Rapor Tarihi	30/09/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. DOM based open redirection

Bu raporda, PortSwigger Web Security Academy'de yer alan DOM based open redirection zafiyetine ilişkin lab ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın istemci tarafı JavaScript kodunda DOM tabanlı açık yönlendirme (open redirection) zafiyeti tespit edilmiştir. Hedef sitenin blog gönderisi sayfasında yer alan “Back to Blog” yani “Blog sayfasına dön” butonunda yer alan yönlendirme fonksiyonunda zafiyet tespit edilmiştir.

Zafiyet bir PoC ile doğrulanmıştır. Açık yönlendirme, kurbanın gerçek siteden geldiğini sanarak saldırgan kontrolündeki bir sayfaya (ör. sahte giriş ekranı) yönlendirilmesine ve bu yolla kimlik bilgilerinin çalınmasına (phishing) olanak tanıyabileceğinden giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef sitenin blog gönderisi sayfasında yer alan “Back to Blog” yani “Blog sayfasına dön” butonunda yer alan yönlendirme fonksiyonunda zafiyet tespit edilmiştir. İlgili fonksiyon, yönlendirme için atanan location değerinde herhangi bir doğrulama yapmamaktadır. Bu da yönlendirme zafiyetine olanak sağlamaktadır.

4. Risk Seviyesi

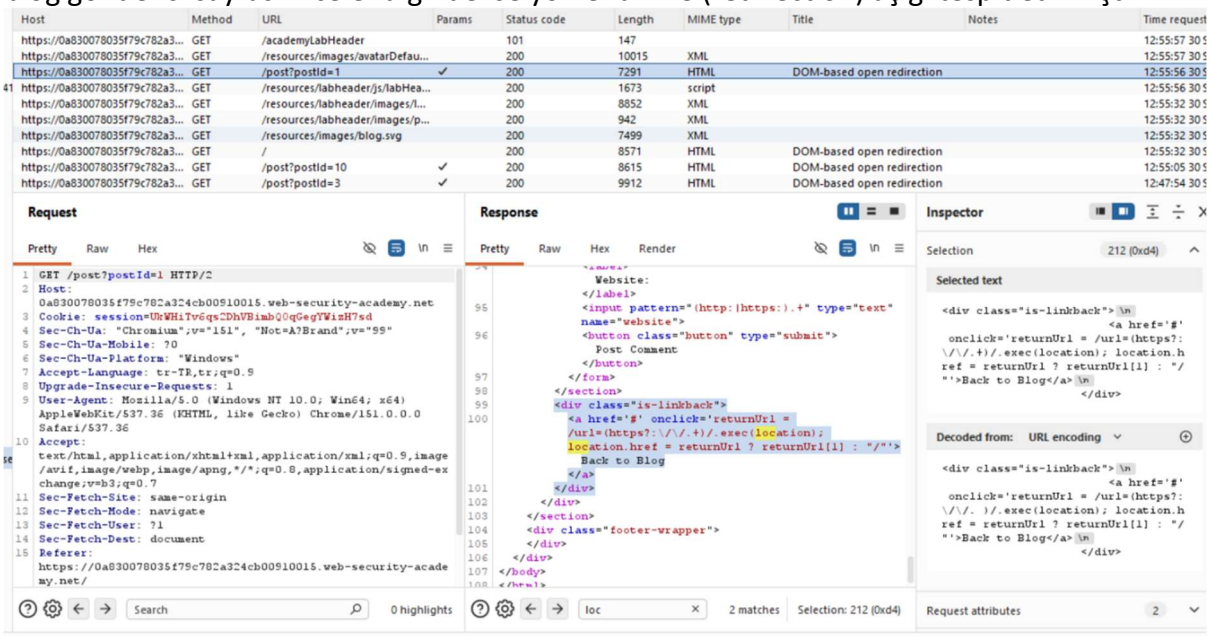
Risk Seviyesi	Orta
CVSS v3.1 Skoru	6.1
CWE	CWE-601

5. Etki

Zafiyetin istismar edilmesi durumunda saldırgan, kurbanı hedef uygulamanın güvenilir alan adı üzerinden kendi kontrolündeki bir adrese yönlendirebilmektedir. Bağlantı, uygulamanın meşru alan adıyla başladığından kurban güvenmeye eğilimli olur.
Bu durum özellikle oltalama (phishing) saldırılarında kullanılabilir: kurban, gerçek siteye ait bir bağlantıya tıkladığını sanarak saldırganın hazırladığı sahte bir sayfaya (ör. taklit giriş formu) yönlendirilir ve kimlik bilgilerini burada girebilir. Ayrıca zararlı yazılım dağıtımı ve uygulamanın itibarının kötüye kullanılması gibi risklere de yol açar.

6. Proof Of Concept

Hedef site incelendiğinde ana sayfada herhangi bir zafiyetle karşılaşılmamıştır. İlgili sitede bir blog gönderisi sayfası incelendiğinde ise yönlendirme (redirection) açığı tespit edilmiştir:



Buradaki ifade url= yazan yeri bulup http veya https ile başlayan kısmı yakalamaya yöneliktir. .exec(location) ifadesi de location üzerinde çalıştırmayı ifade etmektedir. Buradaki location değerinde herhangi bir doğrulama gözlemlenmemiştir. Bu da location ifadesinin değiştirilebileceğini göstermektedir. returnUrl yakalandığı taktirde url= bulunduysa location.href ile o değere yönlendirileceği, bulunamadıysa ana sayfaya yönlendireleceği görülmektedir. Yani ilgili kod, URL'inin içinde url=https://herhangi-bir-şey görürse, kurbanı o adrese yönlendirmekte olup bunu hiçbir kontrol olmadan yapmaktadır.

Regex https?:// istediği için (yani http:// veya https:// ile başlamalı), exploit URL'in de tam bir https://... adresi içermelidir. Buna göre ilgili payload oluşturulur:

https://0a830078035f79c782a324cb00910015.web-security-academy.net/post?postId=1&url=https://exploit-0aed0094033479ad82cc238c01e90041.exploit-server.net/

Burada postId=1 incelediğimiz blog sitesinin Id'sidir.
Bu payload <script></script> etiketi içinde location= değerine atanıp store'landığında blog gönderi sayfasının en altında yer alan "Back to Blog" sayfasına yönlendirme işlemi için payload çalışacaktır.

Body:

```
<script>
  location = "https://0a830078035f79c782a324cb00910015.web-security-academy.net/post?postId=1&url=https://exploit-0aed0094033479ad82cc238c01e90041.exploit-server.net/";
</script>
```

Store View exploit Access log



7. Çözüm Önerisi

Yönlendirme hedefi doğrulanmalıdır. Kullanıcı girdisiyle belirlenen bir adrese doğrudan yönlendirme yapılmamalıdır. Yönlendirme hedefi, izin verilen adreslerden oluşan bir allowlist'e karşı denetlenmeli; mümkünse yalnızca uygulama içi yollara izin verilmelidir. Dış adreslere yönlendirme kısıtlanmalıdır. Uygulamanın kendi alan adı dışına yönlendirme gerekiyorsa, kullanıcı açık bir uyarıyla bilgilendirilmelidir.

8. Sonuç

Yapılan testler sonucunda hedef sitede yönlendirme (redirection) zafiyeti tespit edilmiştir. Zafiyet, kurbanın saldırgan kontrolündeki bir adrese yönlendirilmesine ve oltalama yoluyla kimlik bilgisi çalınmasına kadar ilerleyebilecek etkisi nedeniyle giderilmesi gereken bir bulgu olarak değerlendirilmiştir.